

Security+ 4.6 · Password Security

Mestre CyberSec — PDF baseado na aula do Professor Messer · 4.6 — Password Security (6:22) · [vídeo original ↗](#) · [YouTube ↗](#)

Password: COMPRIMENTO > complexidade (14+ é melhor); password manager (gera forte, guarda cifrado); passwordless (FIDO2/YubiKey, biometria, Magic link) = o futuro; NIST: sem troca forçada (incentiva fraca).

Highlights que a prova cobra

- Comprimento > complexidade (14 chars simples > 8 complexos)
- FIDO2/YubiKey = passwordless: a chave física que não pode ser phishing

Dicas de prova

- 'length over complexity' = NIST 800-63B guidance

Cenário clássico: 'senha de 16 chars simples é melhor que 10 chars complexos' = NIST guidance.

Perguntas de treino (10 questões)

Gabarito no fim. Tenta responder SEM olhar.

1. MFA combina fatores de categorias diferentes. Qual trio representa as 3 categorias?
A) Senha, PIN e resposta secreta
B) Algo que sabe, algo que tem, algo que é
C) 3 senhas diferentes
D) Usuário, senha e e-mail

2. MFA exige pelo menos dois fatores de autenticação. Qual combinação representa autenticação de múltiplos fatores genuína?

- A)** Senha + PIN
- B)** Senha + Token físico
- C)** Dois tipos de biometria
- D)** Pergunta de segurança + Senha

3. A forma correta de ARMAZENAR senhas de usuários:

- A)** Hash com salt (ex: bcrypt)
- B)** Criptografia AES reversível
- C)** Texto claro protegido por firewall
- D)** Base64

4. Cenário corporativo (Password Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: 'Comprimento > complexidade (14 chars simples > 8 complexos)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Comprimento > complexidade (14 chars simples > 8 complexos)...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Password Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: 'FIDO2/YubiKey = passwordless: a chave física que não pode ser phishing'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: FIDO2/YubiKey = passwordless: a chave física que não pode ser phishing...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Password Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: 'length over complexity'=NIST 800-63B guidance'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'length over complexity'=NIST 800-63B guidance...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Password Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: 'senha de 16 chars simples é melhor que 10 chars complexos'=NIST guidance'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'senha de 16 chars simples é melhor que 10 chars complexos'=NIST guidance....

8. Cenário corporativo (Password Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: 'Comprimento > complexidade (14 chars simples > 8 complexos)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Comprimento > complexidade (14 chars simples > 8 complexos)...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Password Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: 'FIDO2/YubiKey = passwordless: a chave física que não pode ser phishing'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: FIDO2/YubiKey = passwordless: a chave física que não pode ser phishing...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Password Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: 'length over complexity'=NIST 800-63B guidance'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'length over complexity'=NIST 800-63B guidance...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO

- 1) B — Algo que sabe, algo que tem, algo que é.** MFA de verdade mistura categorias: conhecimento (senha), posse (token/celular) e inerência (biometria). Três senhas são o MESMO fator — não é MFA.
- 2) B — Senha + Token físico.** MFA verdadeira combina fatores de categorias diferentes: algo que você sabe (senha) + algo que você tem (token físico). Múltiplos fatores da mesma categoria não constituem MFA.
- 3) A — Hash com salt (ex: bcrypt).** Senha se guarda como HASH salgado (bcrypt/argon2) — não reversível. Nunca em texto claro nem cripto reversível (a chave vaza junto).
- 4) A — Implementar a solução correspondente: Comprimento > complexidade (14 chars simpl.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Password Security): Comprimento > complexidade (14 chars simples > 8 complexos). As demais alternativas configuram violações graves de
- 5) A — Implementar a solução correspondente: FIDO2/YubiKey = passwordless: a chave físi.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Password Security): FIDO2/YubiKey = passwordless: a chave física que não pode ser phishing. As demais alternativas configuram violações
- 6) B — Implementar a solução correspondente: 'length over complexity'=NIST 800-63B guid.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Password Security): 'length over complexity'=NIST 800-63B guidance. As demais alternativas configuram violações graves de conformidade
- 7) D — Implementar a solução correspondente: 'senha de 16 chars simples é melhor que 10.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Password Security): 'senha de 16 chars simples é melhor que 10 chars complexos'=NIST guidance.. As demais alternativas configuram viola
- 8) A — Implementar a solução correspondente: Comprimento > complexidade (14 chars simpl.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Password Security): Comprimento > complexidade (14 chars simples > 8 complexos). As demais alternativas configuram violações graves de
- 9) C — Implementar a solução correspondente: FIDO2/YubiKey = passwordless: a chave físi.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Password Security): FIDO2/YubiKey = passwordless: a chave física que não pode ser phishing. As demais alternativas configuram violações
- 10) B — Implementar a solução correspondente: 'length over complexity'=NIST 800-63B guid.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Password Security): 'length over complexity'=NIST 800-63B guidance. As demais alternativas configuram violações graves de conformidade

